

# Bezpečnosť elektronickej pošty – analýza hrozieb a návrh nástroja na detekciu podozrivých e-mailov

Alexander Ovšonka  
STU FIIT  
xovsonka@stuba.sk

**Abstract**—This document is a model and instructions for L<sup>A</sup>T<sub>E</sub>X. This and the IEEEtran.cls file define the components of your paper [title, text, heads, etc.]. \*CRITICAL: Do Not Use Symbols, Special Characters, Footnotes, or Math in Paper Title or Abstract.

**Index Terms**—component, formatting, style, styling, insert.

## I. ÚVOD

## II. TEORETICKÉ ZÁKLADY

### A. Architektúra e-mailovej komunikácie

Elektronická pošta patrí medzi najstaršie a najrozšírenejšie služby internetu. Jej fungovanie je založené na súbore štandardizovaných internetových protokolov a formátov správ, ktoré umožňujú vytváranie, prenos a doručovanie e-mailových správ medzi jednotlivými účastníkmi komunikácie.

Základom e-mailovej infraštruktúry je protokol **SMTP (Simple Mail Transfer Protocol)**, ktorý zabezpečuje prenos e-mailových správ medzi servermi v internete. Formát samotnej e-mailovej správy je definovaný štandardom **Internet Message Format (IMF)**, zatiaľ čo rozšírenie **MIME (Multipurpose Internet Mail Extensions)** rozširuje formát e-mailovej správy tak, aby bolo možné prenášať rôzne typy dát, napríklad binárne prílohy, obrázky alebo HTML obsah.

Architektúra elektronickej pošty je vysoko distribuovaná. Na jej fungovaní sa podieľa viacero komponentov a aktérov, ktorí spolupracujú pri spracovaní a prenose správy od odosielateľa k príjemcovi. Podľa architektúry definovanej v RFC 5598 možno týchto aktérov rozdeliť do niekoľkých základných kategórií.

**Používateľia:** Používateľ predstavuje entitu, ktorá vytvára alebo prijíma e-mailové správy. Používateľom môže byť človek, organizácia alebo automatizovaný proces. V rámci e-mailovej architektúry možno rozlíšiť viacero rolí používateľov.

- **Author (autor)** – entita zodpovedná za vytvorenie správy a určenie jej príjemcov.
- **Recipient (príjemca)** – cieľová entita, ktorej je správa určená.
- **Return handler** – špeciálny typ príjemcu, ktorý prijíma systémové notifikácie generované počas prenosu správy (napr. chybové hlásenia o nedoručení).
- **Mediator** – komponent alebo služba, ktorá prijíma správu, modifikuje ju alebo redistribuuje medzi ďalších príjemcov. Typickým príkladom sú mailing listy alebo automatické presmerovania.

Z pohľadu používateľa sa proces prenosu e-mailu javí ako jednotná služba poskytovaná systémom spracovania správ, nazývaným **Message Handling System (MHS)**. V praxi však môže byť táto služba implementovaná viacerými nezávislými systémami a organizáciami.

**Message Handling System:** **Message Handling System (MHS)** predstavuje infraštruktúru, ktorá zabezpečuje kompletný prenos správy od autora k príjemcovi. Jeho úlohou je vykonať prenos správy spôsobom *store-and-forward*, pri ktorom sa správa postupne prenáša medzi jednotlivými servermi, kým nie je doručená cieľovému príjemcovi.

MHS pozostáva z viacerých komponentov:

- **Message User Agent (MUA)** – klientská aplikácia používaná používateľom na vytváranie, čítanie a odosielanie e-mailových správ.
- **Mail Submission Agent (MSA)** – prijíma správy od MUA a kontroluje ich súlad s pravidlami domény a internetovými štandardmi.
- **Message Transfer Agent (MTA)** – zodpovedá za prenos správy medzi jednotlivými poštovými servermi. Na komunikáciu medzi MTA sa používa protokol SMTP.
- **Mail Delivery Agent (MDA)** – zabezpečuje konečné doručenie správy do mailboxu príjemcu.
- **Message Store** – úložisko správ, z ktorého si používateľ môže svoje e-maily načítať prostredníctvom klienta.

Prenos správy medzi jednotlivými servermi prebieha postupne, pričom každý server správu dočasne uloží a následne ju prepošle ďalšiemu serveru. Tento model komunikácie sa označuje ako **store-and-forward**.

**Relay a Gateway:** V rámci infraštruktúry MHS môžu vysutupovať aj ďalšie komponenty.

- **Relay** – server, ktorý prijíma e-mailovú správu a preposiela ju ďalšiemu serveru smerom k cieľovému príjemcovi.
- **Gateway** – komponent prepájajúci rôzne e-mailové systémy alebo komunikačné protokoly. Gateway môže upravovať obsah správy alebo jej formát tak, aby bola kompatibilná s cieľovým systémom.

**Adresovanie e-mailov:** Každý používateľ e-mailovej služby je identifikovaný pomocou e-mailovej adresy. Tá má všeobecný tvar:

*local-part@domain*

Adresa sa skladá z dvoch častí:

- **local-part** – identifikátor používateľa v rámci konkrétnej domény,
- **domain** – názov domény, ktorá identifikuje poštový server zodpovedný za doručenie správy.

Doménové meno je globálne jedinečný identifikátor internetového zdroja, ktorý sa pomocou systému DNS mapuje na IP adresu servera.

*Identifikácia správ:* Každá e-mailová správa môže byť identifikovaná pomocou jedinečných identifikátorov.

- **Message-ID** – jedinečný identifikátor správy používaný na sledovanie a referencovanie správy v rámci e-mailovej komunikácie.
- **ENVID** – identifikátor používaný pri sledovaní prenosu správy počas jej doručovania v rámci SMTP komunikácie.

Tieto identifikátory umožňujú sledovať stav správy počas jej prenosu a uľahčujú diagnostiku problémov pri doručovaní.

*Asynchrónna komunikácia:* Prenos e-mailových správ prebieha asynchrónne. Správa sa postupne presúva medzi jednotlivými servermi, ktoré ju ukladajú a následne preposielajú ďalšiemu serveru. Tento model komunikácie umožňuje spoľahlivý prenos správ aj v prípade dočasnej nedostupnosti niektorých serverov alebo sieťových spojení.

1) *DNS a MX záznamy:* Pri doručovaní e-mailovej správy je potrebné určiť server, ktorý je zodpovedný za prijatie správy pre cieľovú doménu. Tento proces je realizovaný pomocou systému doménových mien (DNS). Doménové meno predstavuje globálny identifikátor internetového zdroja, ktorý je možné prostredníctvom DNS preložiť na IP adresu konkrétneho servera.

Pri doručovaní e-mailov sa využívajú najmä **MX (Mail Exchange) záznamy**, ktoré určujú poštové servery zodpovedné za prijímanie správ pre danú doménu. Ak server potrebuje doručiť e-mail na adresu napríklad *user@example.com*, najprv z adresy extrahuje doménu *example.com*. Následne vykoná DNS dotaz na MX záznamy tejto domény. Výsledkom môže byť jeden alebo viacero poštových serverov, pričom každý má priradenú prioritu určujúcu poradie použitia.

Server sa následne pokúsi nadviazať SMTP spojenie s poštovým serverom s najvyššou prioritou. Ak sa spojenie nepodarí nadviazať, môže skúsiť ďalší server v poradí. V prípade, že doména nemá definovaný MX záznam, SMTP špecifikácia umožňuje použiť ako cieľový server host definovaný pomocou **A alebo AAAA DNS záznamu**. Tento mechanizmus zabezpečuje spoľahlivé smerovanie e-mailovej komunikácie v distribuovanom prostredí internetu.

2) *SMTP komunikácia medzi servermi:* Prenos e-mailových správ medzi poštovými servermi je realizovaný pomocou protokolu **SMTP (Simple Mail Transfer Protocol)**. SMTP používa model komunikácie klient–server, kde jeden server vystupuje ako klient iniciujúci prenos správy a druhý server ako server prijímajúci správu.

Po nadviazaní TCP spojenia medzi servermi prebieha komunikácia pomocou sekvencie textových príkazov a odpovedí. Komunikácia začína identifikáciou servera pomocou príkazu

**HELO** alebo jeho rozšírenej verzie **EHLO**. Následne odosielať server oznámi adresu odosielateľa pomocou príkazu **MAIL FROM**. Pre každého príjemcu je následne použitý príkaz **RCPT TO**, ktorý identifikuje cieľového adresáta správy.

Po určení všetkých príjemcov je prenesený samotný obsah správy pomocou príkazu **DATA**. Správa obsahuje hlavičky a telo správy vo formáte Internet Message Format. Po úspešnom prenose správy server potvrdí jej prijatie a komunikácia môže byť ukončená príkazom **QUIT**.

SMTP využíva model *store-and-forward*, pri ktorom jednotlivé poštové servery dočasne ukladajú prijaté správy a následne ich preposielajú ďalšiemu serveru smerom k cieľovej doméne. Tento prístup umožňuje spoľahlivý prenos správ aj v prípade dočasnej nedostupnosti niektorých serverov alebo sieťových spojení.

Počas prenosu správy pridáva každý poštový server do hlavičky správy záznam *Received*, ktorý obsahuje informácie o trase doručenia správy. Tieto záznamy umožňujú sledovať cestu e-mailu naprieč jednotlivými servermi a sú dôležité napríklad pri analýze pôvodu podozrivých alebo phishingových správ.

## B. Formát e-mailovej správy

Formát e-mailovej správy je definovaný štandardom **Internet Message Format (IMF)**, ktorý je špecifikovaný v dokumente RFC 5322. Tento štandard definuje syntaktickú štruktúru e-mailových správ, vrátane ich hlavičiek a tela správy [3].

Na najzákladnejšej úrovni je e-mailová správa reprezentovaná ako sekvencia ASCII znakov. Správa je rozdelená do riadkov znakov, pričom každý riadok je ukončený dvojicou znakov **CRLF** (Carriage Return a Line Feed). Podľa špecifikácie nesmie jeden riadok správy presiahnuť 998 znakov a odporúčaná maximálna dĺžka riadku je 78 znakov bez započítania CRLF [3].

E-mailová správa pozostáva z dvoch hlavných častí:

- **Hlavička správy (Header)**
- **Telo správy (Body)**

Tieto dve časti sú od seba oddelené prázdny riadkom.

1) *Hlavička e-mailovej správy:* Hlavička správy obsahuje metadáta popisujúce správu a jej prenos. Je tvorená množinou hlavičkových polí, pričom každé pole má tvar:

*Field – Name : Field – Body*

Názov poľa je tvorený ASCII znakmi a je ukončený dvojbodkou. Obsah poľa môže obsahovať text alebo štruktúrované údaje podľa syntaktických pravidiel definovaných v RFC 5322.

Dôležité hlavičkové polia zahŕňajú najmä:

- **Date** – dátum a čas vytvorenia správy.
- **From** – adresa autora správy.
- **Sender** – identifikuje odosielať v prípade, že správa bola odoslaná v mene viacerých autorov.
- **Reply-To** – adresa, na ktorú majú byť zasielané odpovede.
- **To** – adresa hlavného príjemcu správy.

- **Cc** – adresy ďalších príjemcov správy.
- **Bcc** – skrytí príjemcovia správy.
- **Message-ID** – jedinečný identifikátor správy.
- **In-Reply-To** – identifikátor správy, na ktorú sa odpovedá.
- **References** – identifikátory súvisiacich správ v konverzácii.
- **Subject** – stručný opis obsahu správy.

Hlavičkové polia môžu obsahovať štruktúrované aj neštruktúrované údaje. V niektorých prípadoch môže byť dlhý obsah hlavičky rozdelený do viacerých riadkov pomocou mechanizmu nazývaného *header folding*, ktorý umožňuje zalomiť riadok a pokračovať na ďalšom riadku začínajúcim medzerou alebo tabulátorom [3].

2) *Telo správy*: Telo správy obsahuje samotný obsah e-mailu určený pre príjemcu. Podľa pôvodného formátu RFC 5322 je telo správy tvorené sekvenciou textových riadkov kódovaných v ASCII. Každý riadok musí byť ukončený sekvenciou CRLF a nesmie prekročiť maximálnu dĺžku 998 znakov.

Moderné e-mailové správy však často obsahujú aj iné typy dát, napríklad formátovaný text, obrázky alebo binárne prílohy. Na podporu týchto funkcionalít bol definovaný štandard **MIME (Multipurpose Internet Mail Extensions)** [4].

3) *MIME rozšírenia*: MIME rozširuje základný formát e-mailovej správy o mechanizmy, ktoré umožňujú prenášať rôzne typy dát a viacero častí správy v jednom e-maile. MIME zavádza niekoľko nových hlavičkových polí, medzi ktoré patria najmä:

- **MIME-Version** – identifikuje správu ako MIME kompatibilnú.
- **Content-Type** – určuje typ obsahu správy alebo jej časti (napr. text/plain, text/html alebo image/jpeg).
- **Content-Transfer-Encoding** – určuje spôsob kódovania obsahu správy, napríklad base64 alebo quoted-printable.

Hlavička *Content-Type* umožňuje špecifikovať typ prenášaných dát pomocou tzv. mediálnych typov. Tie sú definované vo formáte *type/subtype*. Napríklad:

- text/plain – jednoduchý text,
- text/html – HTML obsah správy,
- image/jpeg – obrázok vo formáte JPEG.

MIME tiež umožňuje vytvárať viacdiele správy pomocou typu **multipart**. Takáto správa môže obsahovať viacero častí, napríklad textovú verziu správy a HTML verziu alebo rôzne prílohy.

4) *Kódovanie dát*: Pri prenose e-mailov cez SMTP je potrebné zabezpečiť kompatibilitu s prenosovými mechanizmami, ktoré pôvodne podporovali len 7-bitové ASCII znaky. MIME preto definuje rôzne metódy kódovania dát.

Medzi najčastejšie používané patria:

- **7bit** – základný ASCII formát bez rozšírených znakov.
- **8bit** – umožňuje používať znaky mimo základnej ASCII tabuľky.
- **base64** – kódovanie používané najmä pre binárne prílohy.
- **quoted-printable** – kódovanie používané pre text s rozšírenými znakmi.

Tieto mechanizmy umožňujú bezpečný prenos rôznych typov dát prostredníctvom e-mailovej infraštruktúry.

### C. Bezpečnostné hrozby e-mailovej komunikácie

Elektronická pošta patrí medzi najčastejšie využívané komunikačné služby internetu, avšak zároveň predstavuje jeden z najvýznamnejších vektorov kybernetických útokov. Útočníci často zneužívajú e-mailovú komunikáciu na šírenie nevyžiadanych správ, phishingových kampaní, podvodných odkazov alebo škodlivého softvéru. Tieto hrozby môžu viesť k finančným stratám, poškodeniu reputácie organizácií alebo kompromitácii citlivých údajov používateľov [6].

*Spam*: Spam predstavuje rozosielanie nevyžiadanych správ, ktoré sú vo väčšine prípadov distribuované hromadne prostredníctvom e-mailových služieb. Takéto správy sú často využívané na marketingové účely, avšak môžu byť zároveň súčasťou sofistikovanejších útokov, ktorých cieľom je finančný zisk alebo poškodenie používateľov a organizácií [6].

Spamové e-maily môžu obsahovať škodlivé odkazy, podvodné prílohy alebo sa môžu pokúšať presvedčiť používateľa, aby vykonal určitú akciu, napríklad poskytol citlivé informácie alebo navštívil podvodnú webovú stránku. V praxi je často ťažké jednoznačne kategorizovať všetky typy spamových správ, pretože spam predstavuje širokú skupinu rôznych typov útokov a podvodných aktivít [6].

Motiváciou pre šírenie spamových správ je najčastejšie finančný zisk. Útočníci využívajú spam napríklad na šírenie phishingových kampaní, distribúciu škodlivého softvéru alebo propagáciu podvodných služieb. Podľa niektorých odhadov môžu spameri dosahovať značné finančné zisky prostredníctvom masového rozosielania spamových správ [6].

Spamové útoky môžu mať rôzne formy. Medzi najčastejšie patria správy obsahujúce škodlivé odkazy, prílohy so škodlivým softvérom alebo pokusy o phishing a spoofing. Niektorí útočníci sa dokonca snažia obchádzať spamové filtre tým, že škodlivý text ukrývajú v obrázkoch alebo iných multimediálnych prvkoch [6].

*Phishing*: Typický priebeh útoku realizovaného prostredníctvom e-mailovej komunikácie je znázornený na obrázku ???. Phishing predstavuje jednu z najrozšírenejších foriem e-mailových útokov. Pri tomto type útoku sa útočník snaží oklamať používateľa tým, že sa vydáva za dôveryhodnú organizáciu alebo známu osobu. Cieľom phishingu je získať citlivé údaje používateľa, napríklad prihlasovacie údaje, finančné informácie alebo osobné údaje [6].

Phishingové správy často obsahujú odkazy na podvodné webové stránky, ktoré napodobňujú vzhľad legitímnych služieb. Používateľ je následne vyzvaný na zadanie citlivých údajov, ktoré sú následne odoslané útočníkovi. Phishingové útoky môžu byť realizované aj manipuláciou s hlavičkami e-mailovej správy, napríklad úpravou polí *From* alebo údajov SMTP obálky tak, aby správa pôsobila dôveryhodne [6].

Útočníci môžu taktiež manipulovať s doménou uvedenou v príkaze *HELO/EHLO* počas SMTP komunikácie, čím sa snažia vytvoriť dojem, že správa pochádza z legitímneho zdroja [6].

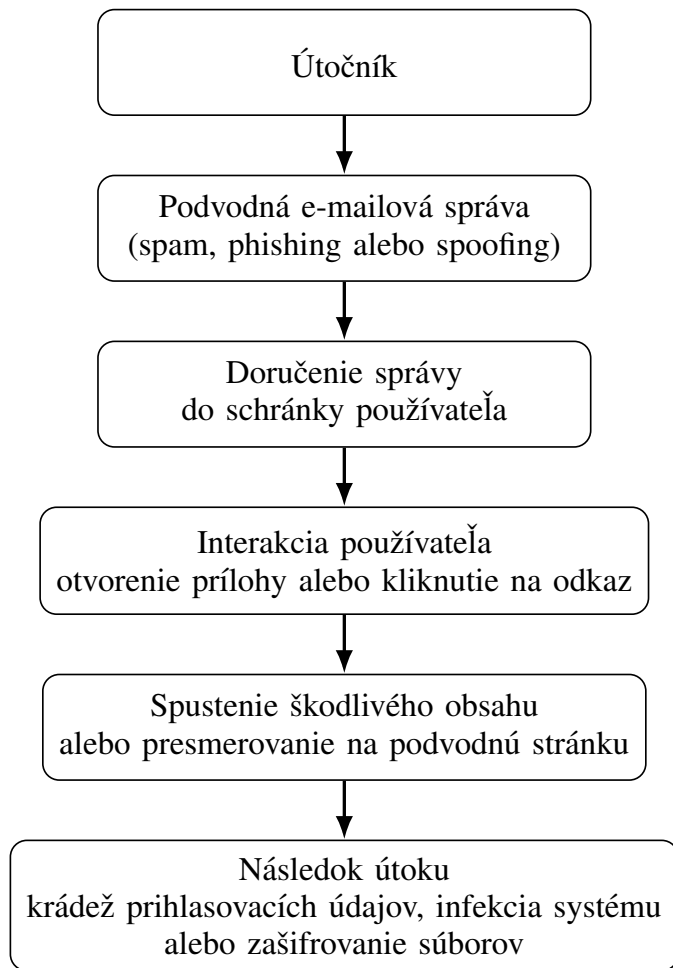


Fig. 1. Model priebehu útoku prostredníctvom e-mailovej komunikácie

*Spear phishing:* Spear phishing predstavuje pokročilejšiu formu phishingového útoku, ktorá je zameraná na konkrétneho jednotlivca alebo organizáciu. Na rozdiel od bežného phishingu sú tieto útoky výrazne personalizované a často využívajú informácie získané prostredníctvom sociálneho inžinierstva [6].

Útočníci sa pri spear phishingu snažia vytvoriť e-mailovú správu, ktorá pôsobí ako legitímna komunikácia od dôveryhodnej osoby alebo organizácie. Personalizácia správy môže zahŕňať použitie mena príjemcu, informácií o jeho pracovnej pozícii alebo detailov o organizácii, v ktorej pracuje. Práve táto personalizácia výrazne sťažuje detekciu takýchto útokov pomocou tradičných spamových filtrov [6].

*Whaling:* Whaling je špecifická forma spear phishingu, ktorá je zameraná na vysoko postavených zamestnancov organizácie, napríklad členov manažmentu alebo vedúcich pracovníkov. Útočníci sa v takýchto prípadoch snažia napodobniť komunikáciu od dôveryhodných osôb, napríklad od generálneho riaditeľa alebo iného člena vedenia organizácie [6].

Obsah takýchto e-mailov často vytvára dojem naliehavej situácie, napríklad urgentnej finančnej transakcie alebo

riešenia zákazníckej sťažnosti. Takéto útoky môžu mať veľmi vážne finančné dôsledky. V minulosti bolo zaznamenaných viacero incidentov, pri ktorých organizácie prišli o milióny eur v dôsledku sofistikovaných phishingových kampaní zameraných na manažment spoločností [6].

*Spoofing odosielateľa:* Spoofing odosielateľa predstavuje techniku, pri ktorej útočník manipuluje s informáciami v e-mailovej správe tak, aby vytvoril dojem, že správa pochádza od dôveryhodného zdroja. V praxi ide najčastejšie o úpravu údajov v hlavičke správy alebo v SMTP obálke, napríklad manipuláciou s poľom *From* alebo inými identifikačnými údajmi odosielateľa.

Pri takomto útoku sa útočník snaží zamaskovať skutočný pôvod správy tak, aby sa správa javila ako odoslaná legitímnou organizáciou alebo známou osobou. Spoofing je často využívaný v kombinácii s phishingovými útokmi, kde cieľom útočníka je získať citlivé údaje používateľa alebo ho presvedčiť, aby vykonal určitú akciu, napríklad otvoril škodlivú prílohu alebo navštívil podvodnú webovú stránku.

Útočníci môžu manipulovať aj s údajmi prenášanými počas SMTP komunikácie, napríklad s doménou uvedenou v príkaze *HELO/EHLO*. Takýmto spôsobom sa snažia vytvoriť dojem, že správa bola odoslaná z legitímneho servera alebo známej domény [6].

Spoofing je umožnený najmä historickým návrhom protokolu SMTP, ktorý pôvodne neobsahoval mechanizmy na overovanie identity odosielateľa. Tento nedostatok bol v priebehu času čiastočne riešený zavedením autentifikačných mechanizmov, ako sú Sender Policy Framework (SPF) alebo DomainKeys Identified Mail (DKIM), ktoré umožňujú overovať autenticitu odosielateľa [6].

*Distribúcia malvéru prostredníctvom e-mailu:* Podľa štúdie sú e-mailové prílohy jedným z najčastejších spôsobov distribúcie ransomvéru a iného malvéru. Útočníci často maskujú škodlivé súbory ako bežné dokumenty alebo archívy, napríklad vo formátoch ZIP, PDF, DOC alebo SCR. Po otvorení takéhoto súboru sa v systéme používateľa vykoná škodlivý kód, ktorý môže napríklad stiahnuť ďalší malvér, získať neoprávnený prístup k systému alebo začať šifrovať súbory používateľa [?].

Jedným z najrozšírenejších typov malvéru distribuovaných prostredníctvom e-mailu je ransomware. Tento typ škodlivého softvéru po infikovaní zariadenia zablokuje prístup k systému alebo zašifruje súbory používateľa a následne požaduje zaplatenie výkupného za ich obnovenie. [?].

Po úspešnom infikovaní systému môže malvér nadviazať spojenie so vzdialeným riadiacim serverom (Command and Control server), ktorý útočníkom umožňuje kontrolovať infikované zariadenie, získavať citlivé údaje alebo distribuovať ďalší škodlivý kód. Takéto infikované zariadenia môžu byť následne zapojené do botnetov, ktoré útočníci využívajú napríklad na šírenie ďalších spamových kampaní alebo na vykonávanie distribuovaných útokov typu Denial-of-Service [?].

*Indikátory podozrivých e-mailov:* Pri analýze e-mailovej komunikácie je možné identifikovať viacero indikátorov, ktoré môžu naznačovať, že správa je podozrivá alebo súčasťou phishingovej či spamovej kampane. Takéto indikátory sa môžu

vyskytovať v hlavičke správy, v odkazoch obsiahnutých v tele správy alebo v samotnom obsahu e-mailu. Identifikácia týchto znakov predstavuje dôležitú súčasť analýzy e-mailovej komunikácie a využíva sa aj v systémoch detekcie phishingu a spamových správ [?], [?].

**Indikátory v hlavičkách e-mailu.** Hlavičky e-mailovej správy obsahujú technické informácie o prenose správy medzi jednotlivými servermi. Analýza týchto údajov môže odhaliť nezrovnalosti alebo manipuláciu s identitou odosielateľa. Medzi časté indikátory patrí napríklad nesúlad medzi adresami uvedenými v poliach *From* a *Return-Path*, podozrivá alebo nezvyčajná reťaz serverov v záznamoch *Received* alebo nezhoda medzi deklarovanou doménou odosielateľa a skutočným serverom, z ktorého bola správa odoslaná [?].

**Indikátory v URL odkazoch.** Phishingové správy často obsahujú odkazy na podvodné webové stránky. Tieto odkazy môžu využívať rôzne techniky na maskovanie skutočnej adresy cieľovej stránky. Medzi typické indikátory patrí použitie domén, ktoré sú vizuálne podobné známym službám (tzv. typosquatting), použitie IP adresy namiesto doménového mena alebo využívanie služieb na skracovanie URL adries, ktoré sťažujú identifikáciu skutočnej cieľovej stránky [?].

**Indikátory v obsahu správy.** Samotný obsah e-mailovej správy môže taktiež obsahovať znaky naznačujúce potenciálne škodlivý charakter správy. Útočníci často využívajú naliehavý alebo manipulatívny jazyk, ktorým sa snažia prinútiť používateľa konať bez dôkladného overenia správy. Typickými príkladmi sú výzvy na okamžité zadanie prihlasovacích údajov, potvrdenie účtu alebo vykonanie finančnej transakcie [?].

**Podozrivé prílohy.** Ďalším častým indikátorom sú prílohy obsahujúce potenciálne škodlivý kód. Útočníci môžu distribuovať malware prostredníctvom dokumentov, archívov alebo spustiteľných súborov, ktoré po otvorení infikujú systém používateľa. Takéto prílohy sú často maskované ako faktúry, formuláre alebo iné legitímne dokumenty a predstavujú jednu z najčastejších metód šírenia škodlivého softvéru prostredníctvom e-mailovej komunikácie [?].

Významným faktorom pri takýchto útokoch prostredníctvom e-mailu je aj využívanie sociálneho inžinierstva. Útočníci často vytvárajú správy, ktoré pôsobia dôveryhodne alebo naliehavo, napríklad ako faktúry, systémové upozornenia alebo bezpečnostné aktualizácie. Cieľom takýchto techník je prinútiť používateľa, aby vykonal požadovanú akciu bez dôkladného overenia dôveryhodnosti správy [?].

#### D. Mechanizmy ochrany elektronickej pošty

**Sender Policy Framework (SPF):** Sender Policy Framework (SPF) je autentifikačný mechanizmus určený na detekciu a prevenciu spoofingu e-mailových adries. Ide o validačný protokol, ktorý umožňuje prijímaciemu mailovému serveru overiť, či e-mail pochádza zo servera, ktorý je autorizovaný vlastníckmi danej domény [6].

Princíp SPF spočíva v publikovaní SPF záznamu v systéme DNS danej domény. Tento záznam obsahuje zoznam IP adries alebo serverov, ktoré sú oprávnené odosielať e-mailové správy

v mene danej domény. Pri prijatí e-mailu prijímací server porovná IP adresu odosielajúceho servera so záznamom SPF uloženým v DNS. Ak sa IP adresa v zozname nenachádza, správa môže byť označená ako podozrivá alebo odmietnutá [?].

SPF sa používa predovšetkým na overenie informácií v SMTP obálke a hlavičkách správy a predstavuje jeden z najrozšírenejších mechanizmov ochrany proti spoofingu e-mailových adries [6].

**DomainKeys Identified Mail (DKIM):** DomainKeys Identified Mail (DKIM) je kryptografický mechanizmus autentifikácie e-mailových správ, ktorý využíva digitálne podpisy na overenie integrity a pôvodu správy. DKIM umožňuje prijímaciemu serveru overiť, že obsah správy nebol počas prenosu zmenený a že správa bola skutočne odoslaná z deklarovanej domény [?].

Mechanizmus DKIM využíva asymetrickú kryptografiu založenú na dvojici kľúčov – verejnom a súkromnom kľúči. Odosielajúci server vytvorí digitálny podpis e-mailovej správy pomocou súkromného kľúča a tento podpis je následne pridaný do hlavičky správy. Prijímací server si následne z DNS záznamu domény odosielateľa vyžiada príslušný verejný kľúč a pomocou neho overí platnosť podpisu [?].

Ak je podpis platný, prijímací server môže potvrdiť, že správa pochádza z deklarovanej domény a jej obsah nebol počas prenosu modifikovaný. DKIM tak výrazne zvyšuje dôveryhodnosť e-mailovej komunikácie a často sa používa v kombinácii s mechanizmom SPF.

Napriek svojim výhodám DKIM nedokáže úplne zabrániť phishingovým útokom, pretože útočníci môžu registrovať vlastné domény a odosielať správy s platným podpisom. Z tohto dôvodu sa DKIM zvyčajne používa spolu s ďalšími mechanizmami ochrany elektronickej pošty [6].

**1) Blacklistové a reputačné systémy:** Okrem autentifikačných mechanizmov, ako sú SPF alebo DKIM, sa pri ochrane elektronickej pošty využívajú aj blacklistové a whitelistové systémy. Tieto mechanizmy umožňujú identifikovať nedôveryhodných alebo naopak dôveryhodných odosielateľov na základe zoznamov IP adries alebo domén, ktoré sú centrálné spravované a pravidelne aktualizované.

**DNS blacklist:** DNS blacklist (DNSBL) predstavuje databázu IP adries alebo domén, ktoré boli identifikované ako zdroj spamových správ. Pri tomto mechanizme e-mailový server vykoná dodatočný DNS dotaz na špecializovaný blacklistový server s cieľom overiť reputáciu odosielateľa. Ak sa IP adresa alebo doména odosielateľa nachádza v blacklist databáze, e-mailová správa môže byť automaticky odmietnutá alebo označená ako spam [6].

DNS blacklisty môžu fungovať dvoma hlavnými spôsobmi. Prvý spôsob spočíva v udržiavaní databázy IP adries mailových serverov, ktoré boli identifikované ako zdroj spamových správ alebo ako servery zneužívané na ich distribúciu [6]. Druhý prístup využíva identifikáciu spamových zdrojov na základe URI adries, najčastejšie domén alebo webových stránok, ktoré sú používané v spamových kampaniach [6].

Napriek svojej efektívnosti majú blacklistové systémy aj niekoľko obmedzení. Jedným z hlavných problémov je schopnosť útočníkov často meniť zdrojové IP adresy alebo domény, z ktorých sú spamové správy odosielené. Útočníci môžu napríklad využívať kompromitované zariadenia alebo botnety, čím výrazne sťažujú identifikáciu skutočného zdroja útoku [6]. Ďalším problémom je čas potrebný na aktualizáciu blacklist databáz. V prípade phishingových kampaní, ktoré využívajú krátkodobu existujúce domény, môže byť reakčný čas blacklist systémov nedostatočný [6].

**Whitelist:** Whitelist predstavuje zoznam dôveryhodných mailových serverov alebo odosielateľov, ktorí sú považovaní za legitímne zdroje e-mailovej komunikácie. Správy odoslané z týchto serverov môžu byť doručované bez prísnej kontroly spamovými filtrami, čo znižuje pravdepodobnosť nesprávnej klasifikácie legitímnych správ ako spam.

Whitelisy sú často spravované priamo organizáciami, ktoré do nich zaraďujú napríklad vlastné mailové servery, obchodných partnerov alebo overené služby. Používanie whitelisticov môže zlepšiť efektívnosť spamových filtrov a znížiť počet falošne pozitívnych detekcií [6].

Významným projektom v oblasti správy blacklistov a whitelisticov je napríklad Spamhaus Project, ktorý vznikol v roku 1998. Tento projekt poskytuje databázy IP adries a domén spojených so spamovými aktivitami, ktoré využívajú mnohé internetové služby a e-mailové servery na znižovanie množstva spamových správ doručených používateľom [6].

**Heuristické a pravidlové filtre:** Heuristické filtre predstavujú tradičný prístup k detekcii nevyžiadaných e-mailových správ. Tieto systémy sú založené na súbore vopred definovaných pravidiel, ktoré analyzujú jednotlivé časti e-mailovej správy, ako sú hlavička, predmet správy alebo samotný obsah e-mailu. Na základe výsledku týchto pravidiel je správa priradená určité skóre, ktoré sa porovnáva s definovanou prahovou hodnotou. Ak celkové skóre prekročí stanovený limit, správa je klasifikovaná ako spam [6].

**Regex filtering.** Jednou z najčastejších implementácií heuristických filtrov je filtrovanie založené na regulárnych výrazoch (Regular Expressions – regex). Regulárne výrazy umožňujú definovať vzory textu, ktoré môžu indikovať prítomnosť spamového obsahu. Takéto pravidlá môžu napríklad identifikovať typické spamové frázy ako “*selected winner*”, alebo “*awarded lotteries*”. Ak e-mail obsahuje takéto výrazy, systém mu priradí určitú váhu a pri prekročení definovaného prahu môže byť správa označená ako spam [?].

**Heuristic filtering.** Heuristické filtre analyzujú aj hlavičku e-mailovej správy, ktorá obsahuje informácie o pôvode, obsahu a prenose správy. Spammeri často manipulujú tieto údaje pomocou techník ako spoofing, aby správa pôsobila legitímne. Heuristické filtre dokážu takéto nezrovnalosti identifikovať napríklad kontrolou formátu hlavičky alebo analýzou reťazca serverov v záznamoch *Received* [?], [6].

**Content-based filtre:** Content-based filtre predstavujú metódu detekcie spamových správ založenú na analýze samotného obsahu e-mailovej správy. Tento prístup skúma

text správy, predmet e-mailu alebo prípadné prílohy s cieľom identifikovať znaky typické pre spamové kampane [6].

Pri tomto prístupe sa jednotlivým slovám alebo frázam priraduje určitá váha podľa toho, ako často sa vyskytujú v spamových správach. Následne sa vypočíta celkové skóre správy, ktoré sa porovnáva s vopred definovanou prahovou hodnotou. Ak výsledné skóre prekročí túto hodnotu, e-mailová správa je klasifikovaná ako spam [6].

Typickým príkladom sú pravidlové expertové systémy, ktoré využívajú zoznam charakteristických spamových kľúčových slov. Napríklad slová ako *cheap*, *mortgage* môžu byť považované za indikátory spamovej komunikácie a prispievajú k výslednému skóre správy [6].

Nevýhodou content-based filtrov je citlivosť na kontext. Systém môže označiť legitímny e-mail ako spam, ak obsahuje slová typické pre spamové správy, hoci sú použité v inom kontexte. Tento problém je známy ako *false positive* detekcia.

Content-based filtre sa od jednoduchých heuristických filtrov odlišujú tým, že sa zameriavajú na celkový význam a štatistické vlastnosti obsahu správy, nielen na prítomnosť izolovaných zakázaných výrazov.

**Kolaboratívne systémy:** Kolaboratívne spamové filtre využívajú informácie získané od viacerých používateľov alebo e-mailových serverov. Základnou myšlienkou je, že spamové správy sú často rozosielené vo veľkom množstve identických alebo veľmi podobných e-mailov. Ak je určitá správa identifikovaná ako spam jedným používateľom alebo serverom, táto informácia môže byť zdieľaná s ostatnými systémami [6].

**Hash sharing.** Pri tejto metóde sa z obsahu e-mailovej správy vypočíta kryptografický hash, ktorý slúži ako jedinečný identifikátor správy. Hash je alfanumerický reťazec, ktorý reprezentuje digitálny odtlačok správy. Poskytovatelia e-mailových služieb môžu tieto hodnoty ukladať do databáz a porovnávať ich s hash hodnotami nových prichádzajúcich správ. Ak sa hash hodnota zhoduje s hodnotou uloženou v databáze spamových správ, e-mail môže byť okamžite označený ako spam [6].

**Distributed Checksum Clearinghouse (DCC).** Distributed Checksum Clearinghouse (DCC) predstavuje kolaboratívny systém na detekciu spamových správ. Systém vypočíta kontrolný súčet e-mailovej správy a ukladá ho do distribúovanej databázy. Pri každom ďalšom označení správy ako spam sa počet výskytov daného kontrolného súčtu zvyšuje. Ak je určitý kontrolný súčet zaznamenaný veľkým počtom používateľov, systém môže s vysokou pravdepodobnosťou identifikovať takúto správu ako spamovú kampaň [?], [6].

Nevýhodou týchto systémov je, že aj malá zmena v obsahu správy môže zmeniť výslednú hash hodnotu, čo útočníci využívajú pri obchádzaní takýchto mechanizmov.

2) **Moderné metódy detekcie:** S rastúcim objemom elektronickej komunikácie a čoraz sofistikovanejšími technikami spamových kampaní sa tradičné metódy filtrovania e-mailov, založené výlučne na statických pravidlách alebo blacklistoch, ukázali ako nedostatočné. Moderné systémy ochrany elektronickej pošty preto čoraz častejšie využívajú prístupy založené na strojovom učení (machine learning) a hlbokom učení (deep

learning), ktoré umožňujú automaticky identifikovať vzory typické pre spamové správy a adaptovať sa na nové typy útokov (Karim et al., 2019). **Machine learning prístupy.** Metódy strojového učenia predstavujú významný pokrok v oblasti detekcie spamu, pretože umožňujú automatickú klasifikáciu e-mailových správ na základe analýzy rôznych charakteristík správy. Takéto systémy sú založené na tréningu klasifikačných modelov na označených datasetoch, ktoré obsahujú príklady legitímnych e-mailov (ham) a spamových správ. Model následne dokáže identifikovať pravdepodobnosť, že nová správa patrí do jednej z týchto kategórií.

Pri klasifikácii e-mailov sa využívajú rôzne typy príznakov, medzi ktoré patria napríklad obsah správy, frekvencia výskytu slov, štruktúra e-mailu, prítomnosť URL adries alebo informácie z hlavičky správy. Medzi najčastejšie používané algoritmy strojového učenia patria napríklad Support Vector Machines, Random Forest alebo logistická regresia. Tieto modely dokážu identifikovať komplexné vzory v dátach a dosahujú vysokú presnosť pri detekcii spamových správ (Karim et al., 2019).

#### **Naive Bayes klasifikátor.**

Jednou z najpoužívanejších metód strojového učenia pri detekcii spamu je Naive Bayes klasifikátor. Tento algoritmus je založený na Bayesovej pravdepodobnostnej teórii a predpoklade nezávislosti jednotlivých príznakov. V kontexte filtrovania e-mailov sa Naive Bayes používa na výpočet pravdepodobnosti, že daná správa je spam na základe výskytu určitých slov alebo charakteristík v texte e-mailu.

Model je tréňovaný na veľkom množstve e-mailových správ, z ktorých sa vypočítava pravdepodobnosť výskytu jednotlivých slov v spamových a legitímnych správach. Pri analýze novej správy algoritmus vypočíta pravdepodobnosť jej zaradenia do každej kategórie a následne ju klasifikuje ako spam alebo legitímny e-mail. Výhodou tejto metódy je jej relatívna jednoduchosť, nízka výpočtová náročnosť a vysoká efektivita pri spracovaní veľkého množstva e-mailov (Karim et al., 2019).

#### **Deep learning prístupy.**

V posledných rokoch sa v oblasti detekcie spamových e-mailov čoraz viac uplatňujú aj metódy hlbokého učenia. Deep learning využíva neurónové siete s viacerými vrstvami, ktoré dokážu automaticky extrahovať komplexné reprezentácie dát bez potreby manuálneho definovania príznakov. Tieto modely dokážu analyzovať nielen jednotlivé slová, ale aj kontext a vzťahy medzi nimi.

Medzi často používané architektúry patria napríklad konvolučné neurónové siete (CNN) alebo rekurentné neurónové siete (RNN), ktoré sú vhodné na spracovanie textových dát. Deep learning modely dokážu identifikovať komplexné jazykové vzory a štruktúry typické pre spamové správy, čím zvyšujú presnosť detekcie v porovnaní s tradičnými metódami. Napriek tomu však vyžadujú väčšie množstvo tréningových dát a vyšší výpočtový výkon (Karim et al., 2019).

V súčasnosti sa moderné systémy ochrany elektronickej pošty často opierajú o hybridné riešenia, ktoré kombinujú tradičné mechanizmy, ako sú blacklisty alebo heuristické pravidlá, s pokročilými metódami strojového učenia

a hlbokého učenia. Takýto viacvrstvový prístup umožňuje efektívnejšie identifikovať spamové správy a reagovať na nové formy e-mailových hrozieb.

#### *E. Analýza existujúcich nástrojov*

**MailHog** je open-source nástroj určený predovšetkým na testovanie emailových aplikácií počas vývoja. Zachytáva odosielané emaily pomocou lokálneho SMTP servera a umožňuje ich zobrazenie prostredníctvom webového rozhrania. Vývojári tak môžu testovať odosielanie emailov bez rizika, že budú skutočne doručené externým používateľom [10].

**GoPhish** je open-source framework určený na simuláciu phishingových kampaní. Umožňuje vytvárať phishingové emaily, pristávacie stránky a sledovať interakcie používateľov, napríklad kliknutia na odkazy alebo zadanie prihlasovacích údajov. Nástroj sa často využíva pri bezpečnostných školeniach a testovaní povedomia používateľov o phishingových útokoch [11].

**PhishTool** je platforma zameraná na analýzu phishingových emailov a podporu reakcie na bezpečnostné incidenty. Umožňuje bezpečnostným analytikom zhromažďovať, analyzovať a kategorizovať phishingové správy. Systém poskytuje nástroje na extrakciu indikátorov kompromitácie (IOC), analýzu hlavičiek emailov a spoluprácu medzi členmi bezpečnostného tímu [12]. Tieto zdroje môžete citovať ako web resources

### III. EXPERIMENTÁLNA ČASŤ

#### *A. Priprava*

V rámci prípravy experimentov boli vybrate verejne dostupné datasety obsahujúce legitímne, spamové a phishingové e-mailové správy. Cieľom bolo vytvoriť kombinovaný datový základ pre tréning klasifikačného modelu aj pre testovanie navrhnutého nástroja v kontrolovanom prostredí.

Použité boli najmä tieto zdroje:

wcukierski/enron-email-dataset (Enron Email Dataset) – obsahuje veľké množstvo legitímnej firemnej komunikácie, vhodnej ako trieda ham. naserabdullahalam/phishing-email-dataset – obsahuje viacero poddatasetov (napr. Nazario, CEAS\_08, SpamAssasin, Nigerian\_Fraud, Ling, Enron, phishing\_email.csv), ktoré pokrývajú spamové a phishingové scenáre. Datasety boli stiahnuté automatizovane pomocou skriptu dataset\_download.py a uložené do projektovej štruktúry:

dataset/source/enron/ dataset/source/phishing/

#### *B. Prostredie:*

Projekt je postavený ako lokálne kontrolované testovacie prostredie na Windows s Dockerom, kde GoPhish generuje testovacie phishing/legitímne kampane a MailHog zachytáva všetku odoslanú poštu bez odoslania na reálny internet. MailHog beží na portoch 1025 (SMTP) a 8025 (web UI/API), GoPhish na 3333 (admin) a 8080 (phishing server), pričom v lokálnom režime je TLS vypnuté (ADMIN\_USE\_TLS=false, PHISH\_USE\_TLS=false). V GoPhish je nastavený sending profile na mailhog:1025, takže každá kampaň ide priamo do



MailHog, kde je možné správy prezerať, exportovať a ďalej analyzovať.

Nad týmto prostredím je pripravená dátová pipeline v Pythone: stiahnutie verejných datasetov (Kaggle), príprava/čistenie dát, automatizované seedovanie kampaní cez GoPhish API, zber správ z MailHog API do .eml a následná analýza. Vyhodnotenie je navrhnuté ako kombinácia heuristickej detekcie (hlavičky, URL indikátory, podozrivé znaky) a ML klasifikácie textu, pričom výsledkom je hybridné rizikové skóre a report s metrikami (accuracy, precision, recall, F1). Tento setup umožňuje reprodukovateľné experimenty a priame porovnanie prístupov: heuristika vs. ML vs. hybrid.

### C. Návrh vlastného riešenia

Priebeh práce – doteraz realizované kroky

Bolo vytvorené lokálne testovacie prostredie na Windows s využitím Docker Compose. Nasadené boli dve hlavné služby: MailHog (SMTP + web UI/API) na portoch 1025 a 8025, GoPhish (admin + phishing server) na portoch 3333 a 8080. V GoPhish bola použitá lokálna konfigurácia bez TLS ( $ADMIN\_USE\_TLS = false, PHISH\_USE\_TLS = false$ ) pre jednoduché laboratórne testovanie. SMTP profil v GoPhish ( $profilMailHogLocal$ ), čím sa všetky kampane doručujú do MailHog. Technické problémy boli vyriešené.

Pri spúšťaní GoPhish kontajnera vznikla chyba `exec ./docker/run.sh: no such file or directory`. Príčina: nekompatibilné konce riadkov (CRLF) v `gophish/docker/run.sh`. Riešenie: skript bol prekonvertovaný na Unix formát (LF), služba bola spúšťaná cez `sh ./docker/run.sh`. Po oprave bol GoPhish úspešne spustený, prebehli DB migrácie a admin server bol dostupný. Priprava datasetov

Bol pripravený skript `dataset_download.py` na automatické stiahnutie a uloženie datasetov. Dátasúukladané do: `dataset/source/enron/dataset/source/phishing/Overením datasetov bolo zistené: niektoré sú maily s phishing (label 0/1), niektoré`

Bol implementovaný `prepare_dataset.py`, ktorý: `načítavšetkyCSVzodataset/source/, normalizuje textové polia`

Celkový počet záznamov: 681869 Distribúcia labelov: 0: 596222 1: 85647 Splity: Train: 545495 (0:476977, 1:68518) Validation: 68187 (0:59622, 1:8565) Test: 68187 (0:59623, 1:8564) Automatizácia kampaní a zberu dát

Bol pripravený `seed_gophish.py`: `čítariadkyzdatasetu, cezGoPhishAPIvytváraGroup, Template, Campaign, a uploaduje napušané dataset/processed/gophish, ee`

Prostredie GoPhish + MailHog je funkčné. Dátová príprava je funkčná a opakovateľná. Základ automatizácie dataset -> GoPhish kampaň -> MailHog -> .eml“ je pripravený. Ďalší krok: dokončiť `analyze_campaign.py` (heuristika + ML + hybrid score) a vyhodnotenie metrik (accuracy, precision, recall, F1).

Rozdelenie dat: zavedeny stratified split 80/10/10 (train/val/test), overena rovnaka distribucia labelov vo vsetkyh splitoch. Kontroly kvality splitu: doplnena automaticka kontrola: stratifikacia labelov, nulovy overlap textov medzi splitmi (zabrana leakage), source balance tabulka.

ML cast: vytvorene skripty: `train_models.py` (baseline modely: `LogisticRegression, NaiveBayes, LinearSVC`), `tune_models.py` (ladenie hyperparametrov + `threshold tuning na val sete`), `compare_models.py` (porovnanie metrik modelov do tabulky/CSV). Metodika hodnotenia: `vyhodnocovathlavneprecision/recall/F1prelabel` =

1(phishing), accuracy, precision, recall, F1. Aktuálny stav: `novene commitnute: compare_models.py, train_models.py, tune_models.py`. `train_model.py` necommitovat: `pycache/*, .pyc` (doplnit do .gitignore)

### D. Testovacie prostredie

### E. Implementácia analyzačného nástroja

### F. Experimenty

## IV. ZÁVER

## REFERENCES

- [1] D. Crocker, “Internet Mail Architecture,” RFC 5598, Internet Engineering Task Force (IETF), Jul. 2009. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc5598.html>
- [2] J. Klensin, “Simple Mail Transfer Protocol,” RFC 5321, Internet Engineering Task Force (IETF), Oct. 2008. [Online]. Available: <https://datatracker.ietf.org/doc/html/rfc5321>
- [3] P. Resnick, “Internet Message Format,” RFC 5322, Internet Engineering Task Force (IETF), Oct. 2008. [Online]. Available: <https://datatracker.ietf.org/doc/html/rfc5322>
- [4] N. Freed and N. Borenstein, “Multipurpose Internet Mail Extensions (MIME) Part One: Format of Internet Message Bodies,” RFC 2045, Internet Engineering Task Force (IETF), Nov. 1996. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc2045>
- [5] N. Freed and N. Borenstein, “Multipurpose Internet Mail Extensions (MIME) Part Two: Media Types,” RFC 2046, Internet Engineering Task Force (IETF), Nov. 1996. [Online]. Available: <https://datatracker.ietf.org/doc/html/rfc2046>
- [6] A. Karim, S. Azam, B. Shanmugam, K. Kannoorpatti, and M. Jonkman, “A comprehensive survey for intelligent spam email detection,” IEEE Access, vol. 7, pp. 168261–168295, 2019. [Online]. Available: <https://ieeexplore.ieee.org/document/8907831>
- [7] M. Jakobsson and S. Myers, *Phishing and Countermeasures: Understanding the Increasing Problem of Electronic Identity Theft*. Wiley-Interscience, 2006. [Online]. Available: <https://download.e-bookshelf.de/download/0000/5686/57/L-G-0000568657-0000568657.pdf>
- [8] K. Aurangzeb, M. Algem, M. Iqbal, and M. Islam, “Ransomware: A Survey and Trends,” 2019. [Online]. Available: [https://www.researchgate.net/publication/317380115\\_Ransomware\\_A\\_Survey\\_and\\_Trends](https://www.researchgate.net/publication/317380115_Ransomware_A_Survey_and_Trends)
- [9] J. Stachowicz, “Analysis of Phishing Emails and Detection Techniques,” M.S. thesis, St. Cloud State University, 2017. [Online]. Available: [https://repository.stcloudstate.edu/msia\\_etds/125/](https://repository.stcloudstate.edu/msia_etds/125/)
- [10] I. Charlie, “MailHog: Email testing tool for developers,” GitHub repository. [Online]. Available: <https://github.com/mailhog/MailHog>
- [11] J. Wright, “GoPhish: Open-source phishing framework,” GitHub repository. [Online]. Available: <https://github.com/gophish/gophish>
- [12] PhishTool, “PhishTool: Platform for phishing analysis and response,” [Online]. Available: <https://www.phishool.com>

IEEE conference templates contain guidance text for composing and formatting conference papers. Please ensure that all template text is removed from your conference paper prior to submission to the conference. Failure to remove the template text from your paper may result in your paper not being published.